Data Classification Standard

Version 1.0. Date 2026-10-13. Owner: Information Security Officer. Review: every year.

This is a template written for a portfolio. It has not been reviewed by a lawyer and no organization has adopted it. Adapt it to your own business, laws and tools before using it.

Purpose and scope

This standard tells everyone how to label data and how to handle it. The higher the level, the stricter the rules. The goal is to protect data in proportion to the harm its exposure would cause. It covers all company data in any form, including files, email, chat, databases, paper and verbal, and applies to employees, contractors and vendors.

The four levels

Level	Meaning	Examples	Harm if disclosed
Public	Approved for release to anyone.	Published web pages, press releases, job postings, marketing brochures.	None. The information is meant to be seen.
Internal	For employees and approved contractors only.	Internal memos, org charts, meeting notes, general procedures, project plans.	Minor. Some embarrassment or a small competitive disadvantage.
Confidential	Sensitive business or personal data for people with a need to know.	Customer lists, contracts, unreleased financial results, employee records, security assessments, vendor questionnaires.	Serious. Financial loss, legal exposure or loss of customer trust.
Restricted	The most sensitive data. Named individuals only.	Passwords, keys and tokens, payment card data, health records, government ID numbers, forensic data from an incident.	Severe. Major harm to people or the business and likely regulatory penalties.

Handling rules

Topic	Public	Internal	Confidential	Restricted
Labeling	Optional.	Label as Internal in the footer or file name where practical.	Label every page or file as Confidential.	Label every page or file as Restricted and list it in the data inventory.
Who may access	Anyone.	Employees and approved contractors.	Named people or roles with a business need, approved by the data owner.	Named individuals only, approved by the data owner and reviewed every quarter.
Storage	Any approved system.	Company approved systems only.	Company approved systems with access controls and encryption at rest.	Approved systems with encryption at rest and access logging. Never on personal devices or removable media.
Sharing inside the company	No limit.	No limit.	Only with people who need it, using links restricted to named people.	Only with named people approved by the owner. No forwarding and no group sharing.
Sharing outside the company	Allowed.	Only with a business reason and never in bulk.	Only with a signed agreement and the data owner's approval.	Only with data owner and security approval, a signed agreement and encryption.
Email and chat	Allowed.	Allowed on company accounts.	Company accounts only. Send links instead of copies where possible.	Do not send. Use the approved secure sharing tool.
Encryption in transit	Not required.	Required. TLS 1.2 or higher.	Required. TLS 1.2 or higher. No public networks without a VPN.	Required. TLS 1.2 or higher, and end to end encryption where available.
Printing	Allowed.	Allowed.	Avoid. Collect at once and shred when done.	Only with owner approval. Shred at once and log it.
Devices	Any device.	Approved apps with MFA on any device.	Company managed devices only.	Company managed devices only. No local copies.
Backups	Standard backups.	Standard backups.	Encrypted backups.	Encrypted backups with restricted access and a restore test every year.
AI tools and outside cloud services	Allowed.	Company approved tools only.	Company approved tools with a signed data agreement only.	Never.
Retention and disposal	Follow the records schedule.	Delete when no longer needed.	Delete on the retention schedule. Wipe or shred.	Delete as soon as the purpose ends. Certified wipe or destruction, recorded.

Classification rules

1. Every data set has an owner. The owner decides its level using the table above.

2. Data with no label is treated as Internal until the owner decides. Anything that looks like Restricted data is treated as Restricted at once.
3. A document that mixes levels takes the highest level in it.
4. Combining data can raise its level. A list of names is Internal. The same list with home addresses and ID numbers may be Restricted.
5. Owners review their levels every year and whenever the use of the data changes.
6. Lowering a level needs the owner's written approval.
7. If you lose Confidential or Restricted data, or see it exposed, report it the same day.

Roles

Role	Responsibility
Data owner	A manager accountable for a data set. Assigns the level, approves access and reviews both every year.
Data custodian	IT and security staff who apply the controls for each level, such as encryption, backups and logging.
Everyone	Handles data according to its level and reports mistakes and incidents the same day.
Information Security Officer	Owns this standard, approves exceptions with the data owner, and reports on compliance.

Exceptions and enforcement follow the Acceptable Use Policy.

Acceptable Use Policy

Version 1.0. Date 2026-10-13. Owner: Information Security Officer. Review: every year.

This is a template written for a portfolio. It has not been reviewed by a lawyer and no organization has adopted it. Adapt it to your own business, laws and tools before using it.

Purpose and scope

This policy tells you how to use company systems, accounts and data safely. It applies to every employee, contractor and vendor who uses them.

You may

1. Use company systems for your work.
2. Use them for brief, reasonable personal tasks that do not break this policy, slow the network or put data at risk.

You must

1. Use your own account and multi factor authentication. Never share a password, code or token.
2. Use the company password manager with long, unique passwords.
3. Lock your screen when you step away and install updates when asked.
4. Handle data by its level in the Data Classification Standard.
5. Report a lost device, a phishing message or a suspected incident the same day. Good faith reports are never punished.
6. Use only approved software, cloud services and AI tools for company data.

You must not

1. Bypass or turn off security controls such as encryption, filters, antivirus or MFA.
2. Install unapproved software or connect unapproved devices to the company network.
3. Put Confidential or Restricted data into personal email, personal cloud storage or unapproved AI tools.
4. Harass anyone, or view, store or share unlawful or offensive material on company systems.
5. Probe, scan or test systems you do not own or are not authorized to test.

Monitoring

The company may monitor the use of its systems for security and legal reasons, as the law allows. Do not expect privacy on company systems.

Exceptions

If you cannot follow a rule for a good business reason:

1. Ask before you act. Send the security team a written request that says what, why and for how long.
2. Security reviews the risk and may require extra controls.
3. The data owner and the Information Security Officer both approve. An exception for Restricted data also needs an executive's approval.
4. Every exception has an end date of no more than 12 months, is logged in the risk register and is reviewed when it expires.

Enforcement

Violations are reviewed by the security team and the person's manager. The outcome depends on intent, impact and history. It can range from a reminder or retraining, to loss of access, to formal discipline up to termination. Vendors face the remedies in their contracts. Unlawful acts may be reported to authorities. Retaliation against anyone who reports in good faith is not allowed.

Acknowledgement

Everyone confirms in writing that they have read this policy when they join and again every year.

Framework Mapping

Each policy element is mapped to a NIST CSF 2.0 subcategory and to NIST SP 800-53 Rev. 5 controls. These are my study mappings, not an official crosswalk.

Policy element	Document	NIST CSF 2.0	NIST 800-53 Rev. 5
Four classification levels with an owner for every data set	Classification standard	ID.AM-05 Assets prioritized by classification, criticality and impact	RA-2
Labeling and the data inventory for Restricted data	Classification standard	ID.AM-07 Inventories of data are maintained	MP-3, CM-8
Access limited to named people, reviewed quarterly for Restricted	Classification standard	PR.AA-05 Access permissions follow least privilege and separation of duties	AC-2, AC-3, AC-6
Encryption at rest for Confidential and Restricted	Classification standard	PR.DS-01 Data at rest is protected	SC-28
Encryption in transit and rules for email and chat	Classification standard	PR.DS-02 Data in transit is protected	SC-8
Rules for sharing outside the company and with AI tools	Classification standard, AUP	PR.DS-02 Data in transit is protected	AC-21, SC-8
Encrypted backups and a yearly restore test for Restricted	Classification standard	PR.DS-11 Backups are created, protected, maintained and tested	CP-9
Retention, secure wipe and destruction	Classification standard	ID.AM-08 Data is managed throughout its life cycle	MP-6, SI-12
Own account, multi factor authentication, no shared credentials	AUP	PR.AA-03 Users and devices are authenticated	IA-2, IA-5
Screen lock and updates	AUP	PR.PS-01 Configuration management practices are applied	AC-11, CM-6
Approved software and devices only	AUP	PR.PS-02 Software is maintained and removed based on risk	CM-7, CM-11
Report incidents and phishing the same day, no retaliation	AUP, Classification standard	RS.CO-02 Stakeholders are notified of incidents	IR-6, AT-2
Written acknowledgement at hire and every year	AUP	PR.AT-01 Personnel are given awareness and training	AT-2, PL-4
Monitoring notice	AUP	DE.CM-03 Personnel activity and technology use are monitored	AC-8, SI-4
Exceptions approved, time limited and logged in the risk register	AUP	ID.RA-06 Risk responses are chosen, planned and tracked	RA-7, CA-5
Enforcement and sanctions	AUP	GV.PO-01 Policy is established, communicated and enforced	PS-8, PL-4
Policy owner, version control and yearly review	Both documents	GV.PO-02 Policy is reviewed and updated	PL-1